Análisis estático y de dependencias

Metodología SAST/SCA — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Objetivo

Buscar secretos versionados, patrones inseguros en el código y vulnerabilidades conocidas en las dependencias, sin modificar el repositorio y sin enviar código a servicios externos más allá de la descarga de reglas y bases de datos de las herramientas.

2 Herramientas

Herramienta	Imagen / versión	Uso
Gitleaks	`ghcr.io/gitleaks/gitleaks:latest`	Detección de secretos en el árbol y en el historial.
Semgrep	`semgrep/semgrep:latest`	Reglas `p/security-audit` y `p/secrets`.
Trivy	`aquasec/trivy:latest`	Vulnerabilidades, secretos y configuración.

Cuadro 1: Herramientas ejecutadas vía Docker el 22 de octubre de 2026.

3 Alcance

- Árbol versionado: 302 archivos, aproximadamente 15,7 MB.
- Historial de Git: 45 commits.
- Dependencias: los 7 archivos `pom.xml`.
- Infraestructura: `infra/docker-compose.yml` y configuración de los servicios.

4 Procedimiento

4.1 Gitleaks

1. Escaneo del árbol con `-no-git`, la configuración `.gitleaks.toml` del repositorio y `-redact` para no imprimir valores sensibles.
2. Escaneo del historial completo con la misma configuración y redacción.
3. Revisión de las reglas y archivos reportados para distinguir hallazgos vigentes de históricos.

4.2 Semgrep

1. Ejecución con las reglas `p/security-audit` y `p/secrets`, `-metrics off` y salida JSON.

2. Clasificación manual de los hallazgos por archivo y contexto: código de producción, scripts de prueba o configuración.
3. Verificación de que los hashes BCrypt reportados son fixtures de pruebas y no credenciales reales.

4.3 Trivy

1. Escaneo `fs` con los escáneres `vuln`, `secret` y `misconfig`.
2. La primera ejecución falló con HTTP 429 de Maven Central al resolver los BOM. Se repitió montando la caché local `~/.m2` y con `--offline-scan`.
3. Escaneo específico de configuración sobre `infra/` y revisión manual del compose ante la ausencia de archivos detectados.

5 Criterios

- **PASS** si no hay hallazgos vigentes o si los hallazgos son falsos positivos demostrables.
- **WARN** si el hallazgo es histórico, está en un archivo eliminado o requiere una decisión de rotación.
- **FAIL** si hay un secreto vigente, una dependencia crítica/alta sin justificar o un patrón inseguro en código de producción.

6 Limitaciones

- Las imágenes usan la etiqueta `latest`; los resultados corresponden a las versiones descargadas el 22 de octubre de 2026.
- Las reglas comunitarias de Semgrep no cubren todos los patrones posibles; no sustituyen una revisión manual.
- Trivy no detectó `docker-compose.yml` como archivo de configuración; se revisó a mano.
- El escaneo de secretos del historial puede marcar valores ya rotados o archivos eliminados; se clasifican caso por caso.

7 Reproducción

```
docker run --rm -v <repo>:/repo ghcr.io/gitleaks/gitleaks:latest \
  detect --source /repo --config /repo/.gitleaks.toml --redact --no-git

docker run --rm -v <repo>:/src semgrep/semgrep \
  semgrep scan --config p/security-audit --config p/secrets \
  --metrics off /src

docker run --rm -v <repo>:/src -v ~/.m2:/root/.m2:ro \
  aquasec/trivy fs --scanners vuln,secret,misconfig \
  --offline-scan /src
```